SecureCorp Security Assessment Engagement

Week 4 — Recommendations & Client Debrief

Prepared by: Junior Security Consultant (Student)

Task 4.1 — Security Recommendations

Each recommendation is tied to a specific finding from Weeks 2–3, with fixes at the technical, compensating-control, and detective-control levels where they apply.

Area	Current State (Evidence)	Technical Fix	Compensating Control	Detective Control	Priority
Vulnerability & Patch Management	vsftpd 2.3.4 backdoor (CVE-2011-2523) gave direct root shell access — Task 2.3	Patch/upgrade vsftpd to a current, non-backdoored release	Restrict FTP exposure to trusted network segments only	Host-based alert on unexpected child processes spawned by the FTP daemon	Critical
Secure Coding / Input Validation	SQLi returned all user records; reflected XSS executed arbitrary script; command injection appended shell output — Tasks 2.5, 2.6	Parameterized queries for all DB access; output encoding on all reflected fields; strict input allowlisting on the ping module	Web Application Firewall (WAF) rule set blocking common injection signatures	Apache access/error log monitoring for injection patterns (currently not possible — log source missing)	Critical
Account Management / RBAC	msfadmin session created an unauthorized account (testuser) and used it to log in — Task 3.3 incident	Enforce least-privilege sudo policy; remove ability for standard accounts to run adduser/useradd; rotate the msfadmin credential immediately	Require secondary approval/change-ticket for any new account creation	Alert on any adduser/useradd executed via sudo; alert on sudo sessions opened from local console by service-style accounts	Critical
Password Policy	Default/weak credentials found on FTP (user:user, service:service, postgres:postgres) and SSH (testuser:test123) — Tasks 2.7, 2.8	Enforce a strong password policy (min length/complexity) across all services; eliminate default and shared credentials	Account lockout / rate limiting after N failed attempts (fail2ban or equivalent)	sshd.log / vsftpd.log monitoring for repeated auth failures — already visible, currently Manual only	High
Logging & Monitoring	No Apache/DVWA access or error log is collected on the log box — confirmed absent, Task 3.2/3.4	Wire the Apache access and error logs into the centralized log box	None available until logging exists — this gap IS the risk	Once wired: alerting on injection-pattern strings and repeated failed DVWA logins	High
Multi-Factor Authentication	All tested remote access (SSH) and the DVWA admin login rely on password-only authentication — Tasks 2.4, 2.8	Deploy MFA for SSH and for the DVWA/portal admin login	IP allowlisting for administrative interfaces as an interim measure	Log and alert on repeated MFA failures	Medium-High
Network Segmentation / Firewall	Nmap enumeration found numerous exposed, non-essential services (RPC, NFS, Samba, VNC, Tomcat, IRC, PostgreSQL, MySQL) — Task 2.1, 2.2	Disable unused services; segment the customer-facing web server from internal/administrative services	Firewall rules restricting each service to only the hosts/ports that need it	Network-level scan/IDS detection for rapid multi-port connection attempts	Medium
Backup & Recovery	Not directly tested in this engagement — general hygiene recommendation	Implement regular, tested backups stored isolated from the production network	N/A	Automated backup-completion / failure alerting	Medium
User Awareness	Not directly tested in this engagement — general hygiene recommendation	Security awareness training covering phishing, credential hygiene, and reporting suspicious activity	N/A	Track training completion; phishing-simulation click-rates	Low-Medium

Task 4.2 — Executive Summary

Overall posture: SecureCorp's customer portal environment has multiple critical weaknesses that would allow an attacker to gain full control of the affected server, steal customer data, and maintain hidden, long-term access — all without being detected by current monitoring.

Most critical findings: An outdated file-transfer service contains a known backdoor that grants immediate, complete control of the server with no password required. Separately, the customer-facing web application does not properly check user

input, which let us extract every customer record from its database and run arbitrary commands on the server. During our investigation we also found evidence of a real, unauthorized intrusion — someone gained access, looked around, and created a hidden backdoor account for themselves — that was not part of our own testing.

Highest business risks: Customer data exposure (breach notification, legal, and reputational cost), complete loss of server control, and — most urgently — an active, unauthorized foothold that we found already present in the environment, which was not being detected by any existing monitoring.

Top recommendations: (1) Patch the backdoored file-transfer service immediately. (2) Fix the input-handling flaws in the web application. (3) Remove the unauthorized account we found and rotate the credential it used to gain access. (4) Turn on logging for the web application — it currently generates no record at all of who accesses it or how, which is the single biggest blind spot in the environment. (5) Add password and multi-factor requirements across remote access and admin logins.

Task 4.4 — Limitations

(Report Appendix A §10 — pulled directly from Task 3.4 detection-coverage notes)

- DVWA was tested only at security level "Low." Medium/High/Impossible levels apply input filtering and would likely block or complicate the SQLi, XSS, and command-injection payloads used here — those levels were not assessed.
- The Apache/DVWA access and error logs are not collected on the log box at all, so the entire web-attack surface (DVWA brute force, SQLi, XSS, command injection) is invisible to this engagement's detection review — confirmed absent, not merely unsearched (Task 3.2).
- The Nmap reconnaissance scan left no auth-log-level trace in the service logs reviewed; without network-level (IDS/flow) logging, this class of activity would go entirely undetected.
- Findings depend on the timestamps recorded during Week 2 attack execution; any activity performed without a recorded timestamp would have been indistinguishable from the seeded incident during Week 3 correlation.
- This engagement used the Core manual-investigation path only; no SIEM (Wazuh) was deployed, so no automated-detection comparison exists — all detection status in this report is "Manual."
- Numerous services identified by Nmap (RPC, NFS, Samba, VNC, Tomcat, IRC, PostgreSQL, MySQL) were catalogued but not further tested — only the FTP backdoor, SSH, and DVWA/HTTP surfaces were exploited in Week 2.
- An isolated lab cannot represent real user behavior, production scale/traffic volume, an EDR agent, or a tuned SIEM — findings on detectability may not transfer directly to a production environment.
- The lab's VMs initially ran on UTM's Shared Network mode rather than a fully isolated network; this was identified and corrected to Host Only mode before Week 2 attacks began, with connectivity re-verified afterward (see Week 1, Network Mode Correction).